

The final selection of possible exam questions for Information Security

Eric Laermans – Dirk Deschrijver

2026-05-06

1 Security cases

Case 1

In March 2025 a security incident occurred within the U.S. administration. Several high-ranking U.S. officials discussed detailed imminent military operations, including specific information about airstrikes (e.g. timing) over regular personal communication devices in a group chat on the Signal messaging app. Furthermore, a journalist was invited by mistake into the group chat.

The information discussed was classified information, that might have endangered the security of the aircraft pilots if it had been revealed to hostile forces.

Explain which security services would be essential for such a discussion about classified information. Which security services might have been breached in this incident? What improvements would you suggest to the approach that had been chosen during this incident?

Case 2

Email accounts may be very vulnerable. A few years ago (2013), it was the Prime Minister of Belgium who made the news because his private email account had been hacked.

Assume you are an ISP. Your clients have the possibility to access their email accounts using either a mail client or webmail.

How would you secure your email service to minimise the risk of client accounts being hacked? Don't forget system security and don't forget to consider the usability of the system. How would you manage the password recovery process (yes, some customers will forget their passwords)?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 3

Design the architecture for a regional/national healthcare data exchange system. This system must enable the exchange of patient records among hospitals, laboratories, and

doctors. It should allow *authorized* healthcare professionals to access patient data. It should also allow patients to have a (possibly limited) view of their own personal medical data.

What are the most essential security services? What security mechanisms would you use to implement those services (be sufficiently specific)? How would you secure the access to the service? What could be remaining vulnerabilities? Don't forget to consider system security and protection against malware. What are the legal aspects you need to take into account.

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 4

A company distributes software updates to millions of users via mirrors and content delivery networks (CDNs). Recent supply-chain attacks have made integrity and authenticity critical.

Design a secure update system. Which security services are required? Which cryptographic mechanisms would you use to authenticate updates and protect against rollback attacks? How would you protect the signing keys? What remaining risks exist?

Case 5

Choosing good passwords and remembering them all may be a hard task for the human mind. Design the security architecture for a password vault service in a public cloud environment (provided by some cloud service provider).

What are the most essential security services? What security mechanisms would you use to implement those services (be sufficiently specific)? How would you secure the access to the service? What could be remaining vulnerabilities? Don't forget to consider system security and protection against malware.

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 6

A company implements two-factor authentication (2FA) for access to its servers (e.g. mail server). This 2FA relies on a password (first factor) and an authenticator app (second factor) installed on a mobile device (e.g. a smartphone). When the user opens the authenticator app, it shows a 6-digit code, which is refreshed every minute.

When the user requests access to the company server from his PC, the user will enter her/his password on her/his PC. The server will then ask for the 6-digit code generated by the authenticator app. Only after validation of this 6-digit code¹ will access be granted to the company server.

¹The present and the immediately previous code generated by the authenticator app will be validated. Other codes will be rejected.

Describe a plausible protocol, with adequate security mechanisms, that could implement such a 2FA.

What are the improvements with respect to simple password-based authentication? What are the possible drawbacks?

What might be the remaining vulnerabilities?

Case 7

A company has suffered ransomware attacks encrypting both production systems and online backups.

Design a backup security architecture that is resilient against ransomware. Which security services are essential? Which cryptographic mechanisms, key-management practices, and system controls would you use? What risks remain?

Case 8

Design a system of single sign-on (SSO) for multiple independent websites. This system should enable the user to login (using a username-password combination) once to the SSO service (this may be a trusted third party) after which the user has access to all the websites for a certain period of time (e.g. 1 hour).

What security mechanisms would you use? What would the messages that are exchanged to achieve the SSO service look like? How would you secure the access to the SSO service? How would you secure password storage and transmission?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 9

A (wireless) Body Area Network (BAN) is a network of wirelessly communicating sensors embedded in wearable computing devices. The sensors typically collect health related data about the person wearing the BAN. These data are then transmitted through the BAN to a collecting device (i.e. a smartphone).

Design a security solution for the collection of data by the BAN, transmission to the smartphone, and storage on the smartphone.

What are the most essential security services? What security mechanisms would you use to implement those services (be sufficiently specific)? What could be remaining vulnerabilities?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Note: sensors in a BAN are typically battery-operated, low-power, resource-constrained (i.e. limited memory, bandwidth, and computational capability) devices.

Case 10

Cars contain a lot of software today, not just for the multimedia system (music, navigation, etc.) but also for more critical systems (brakes, engine control, etc.).

Not all car brands allow for software updates, although updates might be desirable to patch bugs and possible security issues. Some car brands allow software updates at a car dealership or a certified maintenance centre. Other car brands allow wireless updates that do not require returning the car to a dealership.

Suggest an appropriate security solution (don't forget system security) for these software updates for cars (both at a dealership and wireless updates). Which security functions would be essential? Which security protocols, cryptographic algorithms, etc. would you use?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 11

Consider a system allowing people to vote in elections using the Web.

Which security services will be necessary for this purpose? Which security mechanisms and protocol would you use to achieve these security services? What are the possible disadvantages and limitations of this voting method with respect to the traditional voting process?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.). However, the system security (firewalls, IDS, etc.) are out-of-scope for this question.

Case 12

The most recent version of the Belgian eID (electronic identity card) uses an RSA key with a 2048 bit modulus. This is probably still secure for more than a few years.

Which approach would you suggest if a digital signature with a very long validity is required (e.g. 30 years for a mortgage, possibly longer for a marriage)? You need to *guarantee* that the digital signature will remain valid over the entire time span.

Hint: You need to think whether simply a longer key or an alternative algorithm would allow you to *guarantee* that the digital signature will remain valid over the entire time span. You may assume however that no algorithm becomes insecure overnight (just as for MD5, SHA-1, RSA-768, etc. the warnings had been coming for years before their security was broken). You may also use a trusted third party.

Case 13

You have a mail server within a corporate network. You want employees also to be able to read their emails and send emails when they are at home or on the road.

Suggest an appropriate security solution (don't forget system security). Which security protocols, cryptographic algorithms, etc. would you use?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 14

Design the security architecture for a file service in a public cloud environment (provided by some cloud service provider).

What are the most essential security services? What security mechanisms would you use to implement those services (be sufficiently specific)? How would you secure the access to the service? What could be remaining vulnerabilities? Don't forget to consider system security and protection against malware.

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 15

What security services will be needed to enable electronic cash for small on-line payments? What security mechanisms and protocol would you use to implement these security services?

The goal is to develop a user-friendly, but correctly secured, mechanism for paying small amounts online. For these small payments, systems such as credit card, debit card, whether or not using a token such as the Digipass, are not ideal in terms of usability or cost structure.

The emphasis is therefore on ease of use and simplicity of use, but the security must still be sufficient for users to be able to trust the system. Such a system could be somewhat similar to an electronic version of cash.

Consider the following aspects for your implementation:

- Avoid an overly cumbersome payment procedure on the client side (otherwise we might as well use two-factor authentication).
- Avoiding replay is essential. With regular cash, this problem is simple: you hand over the money on payment and printing is (approximately) impossible. With an electronic payment, of course, things are somewhat different.
- If necessary, you may use a trusted third party.

Case 16

A university wants to replace password-based login for students and staff by passkeys (WebAuthn), usable across multiple services (learning platform, email, exam platform). Students use laptops and smartphones, sometimes shared devices.

Design an appropriate security solution. Which security services are essential? Which cryptographic mechanisms and protocols would you choose?

How are keys generated, stored, and used? What threats remain (phishing, malware, lost devices)? Discuss usability trade-offs.

Case 17

A large company operates on two different locations (one in Ghent, the other one in Brussels), each with a local network. The company wants to allow employees securely to access resources from both local networks and also requires both local networks to be secure.

Suggest a suitable security solution (don't forget system security). Which security protocols, cryptographic algorithms, etc. would you use?

Note: I expect you to make a choice and defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 18

An online exam platform combines webcam monitoring, microphone input, screen capture, and AI-based behaviour analysis. The platform stores recordings for later review.

Design the security architecture for this platform. What security services are essential? How would you protect confidentiality, integrity, access control, and privacy of students? Which cryptographic mechanisms would you choose? What legal and ethical constraints apply?

Case 19

Which approach would you suggest if you want to ensure the confidentiality of an electronic document for a long period of time (10 years or even more)? Which algorithms would be suitable to achieve this long term secure storage? What non-cryptographic measures would you suggest? What could be remaining threats?

Case 20

What security services will be needed to achieve a contactless and passive² access badge used to gain entry to a building? What security mechanisms and protocol would you use to implement these security services?

You briefly hold the access badge in front of a contactless badge reader, which will verify the validity of the badge and grant you access to the building if you have the correct access rights.

It should of course be almost impossible to forge an access badge. The system should be sufficiently fast, although the calculation power of the badge is rather limited.



Figure 1: The connected token with card reader

Case 21

You have a security token (with card reader) *connected* by a USB cable to the host. This token (the bank card reader) also has a small display and a small keypad (numerical digits and a few functional keys, e.g. “OK” and “Cancel”), see also Fig. 1. You have installed a security plug-in (software) that enables the communication between your computer/browser and your token. The bank card has already been inserted in the bank card reader.

You see the following instructions on your Web browser when you log in to your bank web site:

1. Card number

Welcome, your card with number 6703 1234 1234 1234 1 has been correctly read by the bank card reader.

2. PIN code

Please follow the instructions on your bank card reader.

The bank card reader then asks for your PIN code

Type your PIN code and press “OK” to log in

(Or cancel the login by pressing “Cancel”)

After having typed your (correct) PIN code on the bank card reader, you are logged in to your bank web site.

How might such a system work (which cryptographic algorithms, which key sizes, which input, etc.)?

How vulnerable is this procedure to malware on the user’s host?

Note: I expect you to make a choice and to defend this choice. Don’t present a range of possible solutions.

A few additional notes:

- The website itself is protected using TLS 1.3 (certificate for 2048 bit RSA public key; The connection is encrypted using AES_256_GCM, SHA-2-384 is the hash function for HMAC, ECDHE is used for the key exchange mechanism, and RSA is used in the server authentication of the handshake).

²“Passive” means it doesn’t contain any batteries or other internal power source.

- If you enter a wrong PIN three times in a row on the card reader, your card will be blocked. To unblock your card, you'll need to use your card in an ATM or to perform a PIN reset in your bank agency

Case 22

A company implements two-factor authentication (2FA) for access to its servers (e.g. mail server). This 2FA relies on a password (first factor) and an authenticator app (second factor) installed on a mobile device (e.g. a smartphone).

When the user requests access to the company server from his PC, the user will enter her/his password on her/his PC. Then the authenticator app (on the user's mobile device) will ask the user to approve this access. Only after this approval will access be granted to the company server.

Describe a plausible protocol, with adequate security mechanisms, that could implement such a 2FA.

What are the improvements with respect to simple password-based authentication? What are the possible drawbacks?

What might be the remaining vulnerabilities?

Case 23

An organization operates a classical RSA/ECC-based PKI but wants to prepare for post-quantum threats without breaking compatibility.

Design a migration strategy. Which hybrid mechanisms would you deploy? How would certificates, signatures, and TLS be adapted? What are the risks of early PQC deployment?

Case 24

Consider a system to input exam scores in a university. The goal is that only lecturers can input scores for their own courses (i.e. no access to students or external actors, and no access to another lecturer's course). Furthermore lecturers should also be able to input scores from home.

Suggest an appropriate security solution (don't forget system security). Which security protocols, cryptographic algorithms, etc. would you use?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 25

You have a so-called HardKey, which is a security token (without card reader, but with a small display, see also Fig. 2) without physical contact³ to the host, allowing you to log in to your bank web site. You see the following instructions on your Web browser:

³This means it cannot receive data from your computer or send data to your computer. You can manually input data using the keypad of the token and the output of the token can be read on its (small) display.

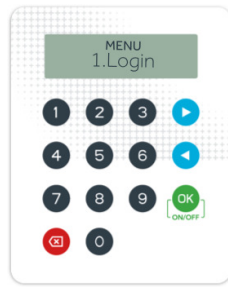


Figure 2: The HardKey security token

1. Enter your username then click on “next step” (both on the web site)
2. Get your HardKey and press the OK button to switch it on
3. When you see “1.Login” press the OK button
4. Enter your PIN on your HardKey and press the OK button
5. Enter the (8 decimal digit) code displayed on your HardKey (on the web site)

How might such a system work (which cryptographic algorithms, which key sizes, which input, etc.)?

How vulnerable is this procedure to malware on the user’s host?

Note: I expect you to make a choice and to defend this choice. Don’t present a range of possible solutions.

A few additional notes:

- The website itself is protected using TLS 1.3 (certificate for 2048 bit RSA public key; The connection is encrypted using AES_128_GCM, SHA-2-256 is the hash function for HMAC, ECDHE is used for the key exchange mechanism, and RSA is used in the server authentication of the handshake).
- If you repeat the procedure with the same input on the token, you’ll obtain a different 8 digit code, which will also be accepted by the website
- After a few minutes, the original 8 digit code will no longer be accepted
- If you attempt to input five erroneous 8 digit codes, your contract will be blocked
- If you enter a wrong PIN three times in a row on the token, your token will be blocked. To unblock your token, you’ll need to contact the bank, which can reset it

Case 26

You may know these remote controls that allow, simply by pressing a button, to lock and unlock the doors of a car.

What security mechanisms could be used to ensure proper and (reasonably) secure operation of these door openers? What threats are there to this security? What vulnerabilities might remain?

Note: When the door opener button is pressed sixteen times out of range, it will no longer work. In this case, a re-initialization of the system will be required from your local distributor.

Note: You shall assume that the door opener only operates as a transmitter, not as a receiver.

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 27

Smart devices (lights, doorbells, locks, thermostats, etc.) can be switched on and off, and controlled using an app on a smartphone.

When you have an existing installation however, you may not want to replace all existing devices with new smart devices. A *smart plug* might be a partial solution in this case. They can be simply plugged into a regular power outlet and will control the electrical power fed to the device plugged into the smart plug (e.g. on/off/dimmed).

The user can control the smart plug using an app on his smartphone. There is also a remote cloud server that can interact with both the controller app and the smart plug. The smart plug is connected to the Internet through the wireless home network.

What are the most essential security services? What security mechanisms could be used to ensure proper and (reasonably) secure operation of these smart plugs? What threats are there to this security? What vulnerabilities might remain?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 28

What security services will be needed to achieve a contactless rechargeable card for public transportation? What security mechanisms and protocol would you use to implement these security services?

These rechargeable card allow the customer to top up their credit (using the ticket machines of the transportation company). This credit can then be used to pay for the use of public transportation. You may consider the simplified scenario where the card permits a certain number of rides at fixed rate.

The card is practically used as a parking badge: you swipe the card in front a contactless card reader, which will decrease the credit on your card by the cost of the ride and will validate your ride. This action must be sufficiently fast and the computing power of a smart card is limited. Examples of such rechargeable cards are the “Mobib” of the MIVB/De Lijn/TEC (Belgium), the “Navigo” of the RATP (Paris), the “Oyster” card of TfL (London), or the “OV Chipkaart” (The Netherlands).

Note: I expect you to make a choice and defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Case 29

Design the security architecture for a backup service in a public cloud environment (provided by some cloud service provider).

What are the most essential security services? What security mechanisms would you use to implement those services (be sufficiently specific)? How would you secure the access to the service? What could be remaining vulnerabilities? Don't forget to consider system security and protection against malware.

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 30

You have a security token (with card reader) without physical contact⁴ to the host, allowing you to confirm a payment (amount: 9.30 EUR) on the Web. After you've entered your credit card data (name, card number, validity limit, verification code), you see the following instructions on your Web browser:

1. Insert your credit card into the card reader
2. Press BUY (*the card reader then asks you for the security code*)
3. Enter the security code 14473738 and confirm with OK (*the card reader then asks you whether you want to buy on the Internet*)
4. Press OK again
5. Enter the amount (9) and confirm with OK
6. Enter your PIN and press OK (*the card reader then shows an 8 digit "signing code"*)
7. Enter the signing code below (*in your Web browser*) and press "Submit"

How might such a system work (which cryptographic algorithms, which key sizes, which input, etc.)?

How vulnerable is this procedure to malware on the user's host?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

A few additional notes:

- The website itself is protected using TLS 1.3 (certificate for 2048 bit RSA public key; The connection is encrypted using AES_256_GCM, SHA-2-384 is the hash function for HMAC, ECDHE is used for the key exchange mechanism, and RSA is used in the server authentication of the handshake).
- If you repeat the procedure with the same input on the card reader, you'll obtain a different "signing code", which will also be accepted by the website

⁴This means it cannot receive data from your computer or send data to your computer. You can manually input data using the keypad of the token and the output of the token can be read on its (small) display.

- After a few minutes, the combination “security code”/“signing code” will no longer be accepted
- If you attempt to input five erroneous “signing codes”, your contract will be blocked
- If you enter a wrong PIN three times in a row on the card reader, your card will be blocked. To unblock your card, you’ll need to use your card in an ATM or to perform a PIN reset in your bank agency

Case 31

Choosing good passwords and remembering them all may be a hard task for the human mind. Design the security architecture for a password manager running on a local device.

What are the most essential security services? What security mechanisms would you use to implement those services (be sufficiently specific)? How would you implement the transfer of the password manager data to a new device? What could be remaining vulnerabilities? Don’t forget to consider system security and protection against malware.

Note: I expect you to make a choice and to defend this choice. Don’t present a range of possible solutions.

Case 32

A mobile app allows users to share their real-time location with selected contacts for a limited time.

Design the security architecture for this system. How do you enforce access control and expiration? How do you protect data confidentiality against the service provider itself? Which cryptographic mechanisms would you select? What legal and privacy constraints apply?

Case 33

A factory deploys thousands of IoT sensors and actuators that communicate with a central control system. Devices have no user interface and limited resources.

Design an authentication and key-management solution. Which security mechanisms and protocols would you use? How are devices enrolled and revoked? What threats remain?

Case 34

Smoke, fire and carbon monoxide detectors are getting smarter (e.g. Google’s Nest Protect).

The smart detector combines a physical smoke detector and an app to be installed on the user’s smartphone. When something is wrong (smoke, fire, etc.), the smart detector will set off an alarm signal and send an alert to the user’s app with information about the detected issue. The user can check the alert and decide whether or not to silence

the alarm using his/her app. The detector connects to the Internet through the wireless home network.

What are the most essential security services? What security mechanisms could be used to ensure proper and (reasonably) secure operation of these smart detectors? What threats are there to this security? What vulnerabilities might remain?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions.

Case 35

Design a secure end-to-end encrypted group messaging system similar to Signal or WhatsApp group chats. Members may join and leave over time.

Which security services are essential? How do you achieve forward secrecy and post-compromise security? Which cryptographic protocols and primitives would you use? What are the remaining vulnerabilities? What legal aspects should you consider?

Case 36

Deutsche Post has introduced a system of 'electronic stamp'. Instead of putting a regular stamp on an envelope, a software program allows you to generate electronic stamps (in PDF format) that you can print on your envelope. You do need Internet access for payment. An example of such an electronic stamp is given in Fig. 3.



Figure 3: Example of an electronic stamp

What security services are needed for proper security of this electronic stamp? What security mechanisms could have been used to achieve those? What threats are there to this security? What vulnerabilities might remain?

Some comments:

- The program provides the following (mandatory) input fields:
 - The destination address (name – street and number – zip code – municipality)
 - The type of letter
 - The Date
- The question deals with the security of the stamp, not the security of the payment mechanism behind it to purchase the electronic stamps.

- In the example of Fig. 3 the real two-dimensional barcode on the right is replaced with a specimen (hence the German inscription “MUSTER”, which of course does not appear on the real barcode)

Case 37

Commercial airliners typically fly with both a pilot and a co-pilot on board. In the future it has been suggested that aeroplanes could be flown with only a single pilot in the cockpit and with a remote co-pilot on the ground, who would be able to take over in case of emergency.

Suggest an appropriate security solution (don't forget system security) for this approach (pilot on-board + remote co-pilot on the ground). Which security functions would be essential? Which security protocols, cryptographic algorithms, etc. would you use?

Note: I expect you to make a choice and to defend this choice. Don't present a range of possible solutions. Be sufficiently specific in your implementation (algorithms, key lengths, modes, etc.).

Note: I know that drones are already operated with remote control only. However a self-destruct function when things really go wrong is not an option for a commercial airliner!

2 Other questions

Question 1

OCB (Offset Codebook Mode) is an authenticated-encryption scheme (as is GCM). It offers both confidentiality and authentication using a symmetric encryption algorithm (block cipher, typically AES). It is also provably secure.

The (somewhat simplified) operation on a message M using a symmetric encryption key K and an encryption algorithm E (AES) is as follows:

1. break the message M into m 128 bit blocks: $M_1, M_2, \dots, M_m$
2. compute $L_* = E_K(0^{128})$ (where 0^{128} is a string of 128 null bits)
3. compute $L_{\S} = x \cdot L_*$
4. compute $L[0] = x \cdot L_{\S}$ and $L[j] = x \cdot L[j - 1]$ (for j ranging from 1 to 127)
5. compute $Z_0 = \text{Init}(N)$, where N is a nonce for the algorithm and Init is an easily computed initialisation function (for which details are skipped here)
6. the offsets Z_i (i ranging from 1 to m) can be computed as $Z_i = Z_{i-1} \oplus L[\text{ntz}(i)]$, where $\oplus$ is the bitwise XOR operation and $\text{ntz}(i)$ is the number of trailing zeros in the binary representation of i (e.g. $\text{ntz}(12) = 2$)
7. compute the ciphertext blocks $C_i = Z_i \oplus E_K(M_i \oplus Z_i)$
8. compute $\text{Checksum} = M_1 \oplus \dots \oplus M_m$
9. compute the authentication tag $T = E_K(\text{Checksum} \oplus Z_m \oplus L_{\S})$
10. the final outcome is $CT = C_1, C_2, \dots, C_m, T$.

All multiplications ($x \cdot$) should be considered as a (polynomial) multiplication with the polynomial x in $\text{GF}(2^{128})$ using the irreducible polynomial $x^{128} + x^7 + x^2 + x + 1$ (cf. GCM).

We have hereby assumed that the length (in bits) of message M is a multiple of 128, that there are no associated data (that must be authenticated, but not encrypted).

Compare the performance of OCB to the performance of GCM: consider parallellisability of encryption, complexity of operations, and potential to pre-compute some partial results.

Question 2

Intrusion detection systems must balance detection accuracy with operational usability.

Explain the concepts of false positives and false negatives in intrusion detection.

Why are false positives often the more severe operational problem in practice?

Discuss how alert fatigue arises and why it undermines security monitoring.

Question 3

Most cryptocurrencies use a proof-of-work for the validation of blocks in the blockchain. This proof-of-work consists in computing some hash algorithm. In the case of Bitcoin the hash algorithm is SHA2-256. A major drawback of this kind of hash function is that traditional computer CPUs are at a significant disadvantage both in speed and in power consumption compared to Application-Specific ICs (ASICs), which can be optimised to perform this single task (i.e. computing SHA2-256 hashes).

Can you suggest alternative hash algorithms that would reduce the advantage of ASICs with respect to CPUs? What properties would be desirable for such hash algorithms?

Note: Don't hesitate to think slightly out-of-the-box of traditional cryptographic hash functions, which are mainly intended for digital signatures and should therefore be very fast to compute.

Note: For those less familiar with hardware: ASICs are dedicated hardware for a single task. They're not reprogrammable (contrary to FPGAs, CPUs, or GPUs) and only have limited integrated random access memory (much less than the typical L3-cache of a CPU).

Question 4

Describe how authenticated Diffie-Hellman (DH) key exchange could work with elliptic curve cryptography (for a given elliptic curve EC with given generator G of known and given order n). What would be the mathematical operations to derive a single-use session key?

Hint: start from the original Authenticated DH key exchange (based on modular exponentiation).

Question 5

The CBC-MAC construction builds a MAC function from a block cipher by taking the last encrypted block of the CBC-mode encryption.

Can a similar (secure) MAC function be derived from OFB-mode encryption? Explain how this derived function would work or why it would not be secure.

Question 6

Describe (with sufficient detail) the TLS (version 1.3) handshake protocol for a client with no certificate and a server using an RSA key (for digital signature only), where elliptic curve ephemeral Diffie-Hellman is used for the key exchange. Explain the mechanisms that are used against possible replay attacks.

What are the advantages and drawbacks of using a combination of ephemeral Diffie-Hellman key exchange and RSA digital signature compared to a situation where RSA would be used for both key exchange and authentication (which was possible in TLS version 1.2)?

Question 7

Blockchain consensus relies on the assumption that the longest available chain is the correct one.

Explain the longest-chain rule used in blockchains such as Bitcoin.

How do forks arise, and how are they resolved?

Discuss under which assumptions this rule is secure, and what happens if these assumptions no longer hold.

Question 8

When browsing the (secure) home page of the university in May 2022, these were the essential security properties I found in the chain of certificates:

- The website (www.ugent.be) uses an RSA-4096 key pair (PR_W, PU_W) . The public exponent of this key is $2^{16} + 1$.
- The key (PU_W) is certified in a X.509v3 certificate $(CA_S \ll W \gg)$ by GEANT TLS RSA 1. This certificate states this key pair is intended for signing and key encipherment, and not for certification (critical V3 extensions). The validity of the certificate is from 2026-04-28 to 2026-11-13. This certificate has been signed using SHA2-256 as a hash function and the RSA-3072 private key (PR_S) of GEANT TLS RSA 1 (the public exponent of this key is also $2^{16} + 1$).
- The corresponding public key (PU_S) of GEANT TLS RSA 1 has in its turn been certified in a X.509v3 certificate $(CA_U \ll S \gg)$ by HARICA TLS RSA Root CA 2021. This certificate states this key pair is intended for signing, for signing CRLs, and for signing (final) certificates (as a CA) (critical V3 extensions). The validity of the certificate is from 2025-01-03 to 2039-12-31. This certificate has been signed using SHA2-256 as a hash function and the RSA-4096 private key (PR_U) of HARICA TLS RSA Root CA 2021 (the public exponent of this key is also $2^{16} + 1$).
- Finally, the corresponding public key (PU_U) of HARICA TLS RSA Root CA 2021 is certified in a self-signed X.509v3 certificate $(CA_U \ll U \gg)$. This certificate states this key pair is intended for signing, for signing CRLs, and for signing (final or intermediate) certificates (as a CA) (critical V3 extensions). The validity of the certificate is from 2021-02-19 to 2045-02-13. This certificate has been signed using SHA2-256 as a hash function.
- All signatures use PKCS #1 v1.5 formatting.

Explain why the different security choices (algorithms, key lengths, validity periods) do or don't make sense.

Explain why you would keep or change these security choices.

Question 9

The TLS 1.3 handshake achieves mutual agreement on keys while authenticating the server.

Explain how server authentication is achieved in the TLS 1.3 handshake.

What is the purpose of the Certificate, CertificateVerify, and Finished messages?

Why is the Finished message cryptographically essential even after certificate verification?

Question 10

HMAC is the most commonly used message authentication code based on a hash function:

$$HMAC = H[(K^+ \oplus opad) || H[(K^+ \oplus ipad) || M]] \quad (Q10.1)$$

A possible simplification of HMAC might be:

$$SimpleHMAC = H[(K^+ \oplus ipad) || M] \quad (Q10.2)$$

Why is this SimpleHMAC (Q24.9) unsuitable as a message authentication code? Explain how, given a message M and its SimpleHMAC, you could construct the SimpleHMAC of some related message M' without knowing the key K^+ .

Note: the hash function used in (Q24.9) may be either MD5, SHA-1, or SHA-2 (not SHA-3).

Question 11

A basic password storage mechanism is to encode a combination of the password and a salt using a one-way function.

A commonly used one-way function is MD5. An alternative one-way function is bcrypt, in which a lengthy (and configurable) setup process may increase the required computation time for the output of the one-way function up to 100 ms on a regular PC.

What is the advantage (consider performance and security) of using bcrypt instead of MD5 for password storage? Are there also possible drawbacks (consider again performance and security) in using bcrypt instead of MD5? Consider the case of a smartphone, the case of a PC, and the case of a server.

Note: the precise working of bcrypt is not relevant for answering this question.

Question 12

If you need a cryptographic hash function and you have to choose between SHA-2 and SHA-3, which algorithm would you choose and why?

What are the respective advantages and drawbacks of each algorithm?

What would determine your choice?

Question 13

Explain with sufficient detail how the dialogue between a client (C) and a Kerberos ticket granting server (TGS) works.

What are the elements that guarantee the authenticity of the involved entities (C and TGS)? What are the possible consequences if an intruder succeeds in capturing the ticket granting ticket (TGT)? How is replay prevented? What cryptographic algorithms could be used (algorithm, mode, key length, etc.)?

Note: you may assume that only symmetric encryption mechanisms are used in this dialogue.

Question 14

One of the fundamental challenges in digital currencies is the double-spending problem.

Explain the double-spending problem in electronic currencies.

Why is this problem easy to solve with a trusted third party (TTP) but difficult in a fully decentralised system?

Explain how the blockchain structure and consensus mechanism address this problem without relying on a TTP.

Question 15

There is a modified version of TLS (DTLS aka Datagram TLS) allowing to offer some kind of TLS over UDP.

Which elements of the TLS Handshake and of the TLS Record Protocol should be modified to allow operation on top of UDP (instead of TCP)?

Reminder: for those who might have forgotten what UDP is, this is a very basic transport layer protocol, running on top of IP; it is connectionless, unreliable, but fast. Packets may arrive out of order or not at all.

Note: don't attempt to include all TCP features in TLS!

Question 16

Explain why AES-GCM (Galois Counter Mode) can be more efficiently parallelised than a combination of AES-CTR (counter mode) for confidentiality with an AES-based CBC-MAC for authentication.

Show as an illustration how the AES-GCM algorithm could be efficiently parallelised over 4 processors.

Note: consider the simplified case for GCM with a 96 bit IV and with no additional authenticated data. The message to be encrypted is at least a few kilobytes, which means that a reasonably large number of blocks will have to be encrypted.

Question 17

Consider the following implementation of a hash function H_T

$$H_T(M) = H(M_1) \oplus \dots \oplus H(M_n) \quad (\text{Q17.3})$$

where H is a traditional hash function (MD5, SHA1, SHA2-256, etc.), where M is the message to be hashed, and M is the concatenation of n individual data blocks M_i (with

$i \in 1..n$), which are sufficiently small to be a single input data block for the hash function H :

$$M = M_1 || \dots || M_n \quad (\text{Q17.4})$$

What are possible advantages of H_T ? What are possible security issues? Is it still a one-way function, does it still exhibit weak and strong collision resistance (consider the case where H is MD5 and the case where H is SHA2-256)?

Question 18

When looking at the root certificates of my browser (Firefox, May 2026) I found the following properties for the GlobalSign Root CA X.509v3 certificate:

- The certificate is valid from 1998-09-01 to 2028-01-28.
- The public key is a 2048 bit RSA key (the public exponent is $2^{16} + 1$).
- The certificate is self-signed using SHA-1 as a hash function and using PKCS #1 v1.5 formatting.
- The critical extensions mention this is a certificate for a certificate authority and the key pair is intended for certificate signing and for CRL signing.

Explain why the different security choices (algorithms, key lengths, validity periods, extensions) do or don't make sense.

Explain why you would keep or change these security choices.

Question 19

(Perfect) Forward Secrecy for a communication channel means previously exchanged session keys remain secret, even when a fixed secret or private key that was used in the key exchange for these session keys is compromised.

Why can't this be achieved using an RSA key exchange? How could an attacker who knows the compromised RSA private key decrypt previous key exchanges?

Which key exchange mechanisms do provide (Perfect) Forward Secrecy? What happens in these cases when the (fixed) private key used in the key exchange is compromised?

Question 20

When browsing the (secure) home page of the healthcare platform CoZo in May 2026, these were the essential security properties I found in the chain of certificates:

- The website (www.cozo.be) uses an RSA-4096 key pair (PR_W, PU_W) . The public exponent of this key is $2^{16} + 1$.

- The key (PU_W) is certified in a X.509v3 certificate ($CA_T \ll W \gg$) by R12 (Let's Encrypt). This certificate states this key pair is intended for signing and key encipherment, and not for certification (critical V3 extensions). The validity of the certificate is from 2026-03-19 to 2026-06-17. This certificate has been signed using SHA2-256 as a hash function and the RSA-2048 private key (PR_T) of R12 (Let's Encrypt) (the public exponent of this key is also $2^{16} + 1$).
- The corresponding public key (PU_T) of R12 (Let's Encrypt) has in its turn been certified in a X.509v3 certificate ($CA_D \ll T \gg$) by ISRG Root X1. This certificate states this key pair is intended for signing, for signing CRLs, and for signing (final) certificates (as a CA) (critical V3 extensions). The validity of the certificate is from 2024-03-13 to 2027-03-12. This certificate has been signed using SHA2-256 as a hash function and the RSA-4096 private key (PR_D) of ISRG Root X1 (the public exponent of this key is also $2^{16} + 1$).
- Finally, the corresponding public key (PU_D) of ISRG Root X1 is certified in a self-signed X.509v3 certificate ($CA_D \ll D \gg$). This certificate states this key pair is intended for signing, for signing CRLs, and for signing (final or intermediate) certificates (as a CA) (critical V3 extensions). The validity of the certificate is from 2015-06-04 to 2035-06-04. This certificate has been signed using SHA2-256 as a hash function.
- All signatures use PKCS #1 v1.5 formatting.

Explain why the different security choices (algorithms, key lengths, validity periods) do or don't make sense.

Explain why you would keep or change these security choices.

Question 21

Compare the signature schemes PKCS #1 v1.5 and PKCS #1 v2.1 (RSA-PSS) for RSA.

Explain how signature *verification* works for an RSA-PSS signed message. Which elements prevent the problems one may encounter using the “raw” RSA algorithm for digital signatures? Can you explain why RSA-PSS may be an improvement over the older PKCS #1 v1.5? Which elements are responsible for this improvement? Would the use of MD5 as a hash function in RSA-PSS be a security risk?

Question 22

Is it possible efficiently to parallelise the encryption operation of a block cipher in CBC mode? If so, explain how. Otherwise, explain why it is not possible.

What about the decryption operation?

Question 23

Describe how AES-GCM is used in TLS v1.3 to encrypt subsequent fragments.

How are the counter values determined? What “associated data” will be authenticated but not encrypted and why?

Question 24

Discuss the potential challenges in the implementation of the RSA algorithm for a solution requiring digital signatures and the public key encryption of symmetric keys.

Consider key generation, key management, and regular use (i.e. digital signatures and public key encryption).

Question 25

Explain why CBC-MAC is not secure for variable-length messages and describe the potential vulnerabilities that arise.

Why is this not an issue with CCM-mode encryption?

Question 26

It is possible to speed up the computation of an RSA digital signature using the Chinese Remainder Theorem (CRT). However, it is often advised to verify the correctness (simply by verifying the obtained signature) of the signature before publishing the signature.

Why is it advised to verify the signature before publishing it? To what extent does it reduce the obtained speed-up of the digital signature (*calculate this*)?

Question 27

Post-quantum cryptography introduces new practical challenges beyond purely theoretical security.

Discuss the main practical challenges in deploying post-quantum cryptography, including:

- key and signature sizes,
- computation and memory requirements,
- interoperability and backward compatibility,
- long-term confidence in security assumptions.

Explain why quantum safety is still considered conjectural.

Question 28

We have seen in the course how the use of a *salt* in the encoded storage of a password could improve the security of the storage. The salt is typically unique for each user, but not secret (it is often stored in plain text).

An alternative technique is using both a *salt* and a *pepper* in the encoded storage. The pepper is identical for all users within the system but secret (only known to the

application processing the passwords and not stored in plain text). This means that the password P_i for some user i (with salt S_i) will be stored as the encoded password EP_i :

$$EP_i = H(P_i || S_i || Pepper) \quad (\text{Q28.5})$$

where *Pepper* is the pepper used in this system, H is the (one-way) encoding function, and $||$ stands for the concatenation of data.

Compare this use of a pepper + salt combination to the use of only a salt or only a pepper for secure password storage. What are the advantages/drawbacks of this pepper + salt combination?

Consider direct login attempts, dictionary attacks, and rainbow tables.

Question 29

We have discussed the vulnerability of RSA to side-channel attacks.

Discuss the vulnerability of elliptic curve cryptography (ECC) to side-channel attacks. Identify the types of side-channel attacks that can affect ECC implementations and describe the countermeasures that can be employed to mitigate these vulnerabilities.

Question 30

Learning With Errors (LWE) is a fundamental hard problem underlying several post-quantum schemes.

Explain the following things

- what is meant by *quantum safety*, and discuss the limitations of this notion;
- why LWE is believed to be a quantum safe algorithm;
- how LWE enables public key encryption;
- the role of noise in LWE;
- how LWE is related to lattice problems.

Question 31

A *ring signature* is a special type of digital signature. The signature can be performed by any member of a group of users. Anyone (given the ring signature and the public keys of all group members) can verify the authenticity of the signature, but not determine *which* member of the group has created the signature.

We consider a group with 4 members (this can be easily generalised to any number of members) using RSA key pairs (KU_i, KR_i) ($1 \leq i \leq 4$) and assume the signer is user number 3.

The procedure uses a keyed function $C_{k,v}(y_1, y_2, y_3, y_4)$ (depending on a key value k and a glue value v). The tuple y_1, y_2, y_3, y_4 will be chosen such that the ring equation holds:

$$C_{k,v}(y_1, y_2, y_3, y_4) = v \quad (\text{Q31.6})$$

The practical implementation of the keyed function $C_{k,v}(y_1, y_2, y_3, y_4)$ is:

$$E_k(y_4 \oplus E_k(y_3 \oplus E_k(y_2 \oplus E_k(y_1 \oplus v)))) \quad (\text{Q31.7})$$

where E_k is the symmetric encryption (consider AES-256) using key value k (the corresponding decryption could be written as D_k), and where $\oplus$ is the bitwise XOR operation.

The signature is generated (by user 3) as follows:

1. the key value k is computed from the message using a (given and known) cryptographic hash function H (e.g. SHA2-256): $k = H(M)$ (truncation to the required key length is allowed)
2. a random glue value v is chosen
3. random values x_i ($1 \leq i \leq 4 \wedge i \neq 3$) are chosen
4. the corresponding values $y_i = E_{KU_i}(x_i)$ are used (with E_{KU_i} the RSA encryption with the public key KU_i) ($1 \leq i \leq 4 \wedge i \neq 3$; no PKCS #1 formatting is used)
5. the ring equation (Q4.1) is solved for y_3
6. the value of $x_3 = E_{KR_3}(y_3)$ is determined
7. the ring signature for message M is the 9-tuple $(KU_1, KU_2, KU_3, KU_4, v, x_1, x_2, x_3, x_4)$

The verification of the ring signature is as follows:

1. compute the values $y_i = E_{KU_i}(x_i)$
2. calculate the key value $k = H(M)$
3. verify that the ring equation (Q4.1) holds

How can the ring equation (Q4.1) be solved for y_3 ? Explain why someone outside the group (without knowledge of any of the private keys KR_i) can't generate a ring signature for the group. Explain why it isn't possible to identify which member of the group has generated the ring signature.

Question 32

Post-quantum cryptography (PQC) should be resistant to quantum computer attacks like Shor's algorithm, which would make non-PQ asymmetric encryption (e.g. RSA or ECC) obsolete.

However, PQC has not been as thoroughly tested as non-PQ cryptography and might be vulnerable to non-quantum attacks. This is why so-called "hybrid encryption" has been proposed, which combines a PQC algorithm with a more proven non-PQ algorithm. The goal is to guarantee at least protection against non-quantum attacks and, hopefully (if the PQC algorithm holds), also quantum-resistant security.

Consider the case of a digital signature.

Suggest a hybrid encryption solution that is secure against both non-quantum attacks and post-quantum attacks against authentication and (partial) data-integrity.

What are the advantages, risks, and drawbacks of this hybrid encryption approach?

Question 33

Given an RSA private and public key pair (private exponent d , public exponent e , and public modulus n), explain the process of factoring the RSA modulus n . Provide a step-by-step explanation of how one can derive the prime factors p and q of n using the private key information.

Question 34

Intrusion detection systems are commonly based on either statistical methods or rule-based approaches.

Compare statistical detection of anomalous behaviour with rule-based detection using expert-defined rules.

For each approach, discuss:

- strengths and weaknesses,
- types of attackers it is better suited to detect,
- dependence on prior knowledge of vulnerabilities.

Explain why hybrid IDS solutions are commonly used.

Question 35

Compare the encryption schemes PKCS #1 v1.5 and PKCS #1 v2.0 (RSA-OAEP) for RSA (for public key encryption).

Explain how *decryption* works for an RSA-OAEP encrypted message. Which elements prevent the problems one may encounter using the “raw” RSA algorithm for public key encryption? Can you explain why RSA-OAEP may be an improvement over the older PKCS #1 v1.5? Which elements are responsible for this improvement? Would the use of MD5 as a hash function in RSA-OAEP be a security risk?

Question 36

IPsec provides security services through the Authentication Header (AH) and the Encapsulating Security Payload (ESP).

Compare AH and ESP in terms of:

- security services offered,
- protection of IP header fields,
- deployment practicality.

Why is AH often omitted in modern IPsec deployments?

Question 37

There is a variant for RSA encryption (*multi-prime RSA*), where the modulus n is a product of a certain number ($k > 2$) of different primes p_i ($1 \leq i \leq k$).

$$n = \prod_{i=1}^k p_i \quad (\text{Q37.8})$$

You may assume that all prime factors p_i are of the same order of magnitude.

The RSA-operations are completely similar: $C = M^e \bmod n$ for the public key encryption of a message M into a ciphertext C using the public exponent e ; $M = C^d \bmod n$ for the decryption using the private exponent d , where $e \cdot d = 1 \bmod \phi(n)$.

The modulus n can, of course, be factorised using the general number field sieve (GNFS), but it can also be factorised using the elliptic curves method (ECM). The complexity for factoring using ECM is:

$$(\lg n)^2 \cdot L_p[1/2, \sqrt{2}] \quad (\text{Q37.9})$$

where p is a prime factor of n .

Consider the case of a 8192 bit RSA key. On the one hand you have a multi-prime RSA key, where the modulus is the product of four 2048 bit primes. On the other hand you have a traditional 8192 bit RSA key, where the modulus is the product of two 4096 bit primes.

To what extent could a multi-prime RSA key be faster than a traditional RSA key? Consider key generation. Consider encryption (using the public key) and decryption (using the private key). Explain how the performance improvement is obtained.

Hint: Think of what you could do using the Chinese Remainder Theorem (CRT).

Note: Don't worry about the security of the multi-prime RSA key for the case considered here. There is no significant degradation of the security with respect to a traditional RSA key of same length.

Question 38

A Merkle tree (aka hash tree) is used in the bitcoin Blockchain technology, but could also be seen as a normal hash function H_{MT} . In short, it consists of a tree of hashes in which the leaves are hashes of data blocks. This is illustrated for a (binary) Merkle tree of depth 2 in Fig. 4.

A more rigorous description for a binary Merkle tree of depth n is:

- The data T are divided in 2^n blocks T_i of equal size (padding may be needed, but we shan't consider it here to keep things simple) (with $i \in 0..(2^n - 1)$), so that T is the concatenation of all blocks T_i : $T = T_0 || T_1 || \dots || T_{2^n-1}$
- Each block T_i is then hashed using a hash function H : $h_{0,i} = H(T_i)$ (with $i \in 0..(2^n - 1)$)
- The intermediate hash values are then combined and hashed to obtain the parent hash nodes: $h_{j+1,i} = H(h_{j,2i} || h_{j,2i+1})$ (with $j \in 0..(n - 1)$ and $i \in 0..(2^{n-j-1} - 1)$)

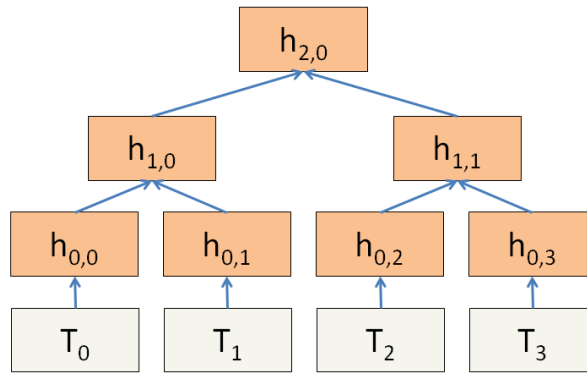


Figure 4: Illustration of a (binary) Merkle Tree (depth 2).

- The final hash value is then $H_{MT}(T) = h_{n,0}$

The hash function H is a traditional cryptographic hash function (MD5, SHA1, SHA2-256, etc.).

- Compare the performance of the computation of H_{MT} to that of a regular hash function H (consider parallelisability).
- If the depth n of the Merkle tree isn't given, this scheme doesn't exhibit weak collision resistance (aka second preimage resistance). Find some data T' such that $T' \neq T$ and $H_{MT}(T') = H_{MT}(T)$.

Extra: Can you adapt the basic scheme of the computation of the Merkle tree to avoid this issue (beyond using a fixed depth n)?

- For a given depth n , does H_{MT} exhibit (strong) collision resistance if MD5 is chosen as a hash function H ? Explain your answer.

Question 39

Consider the following security transformation on a message M :

$$E_K(M) || H(M) \quad (\text{Q39.10})$$

where E_K is a symmetric encryption algorithm (with shared secret key K , at least 128 bits long), and H is a hash function.

How well does this implement the confidentiality and (partial) data-integrity functions? What could be possible issues? Does the quality of this security transformation depend on the encryption algorithm chosen? On the encryption mode chosen? On the hash function chosen?

Note: The shared secret key K can be used for a (reasonably) large number of messages.

Question 40

Blinding is sometimes used to prevent timing attacks against private key operations in RSA.

Design a similar blinding operation for elliptic curve cryptography (for a given elliptic curve EC with given generator G of given order n).

Question 41

Classical system security relies heavily on the concept of a network perimeter.

Explain why firewalls alone are insufficient to protect modern systems.

Discuss at least three concrete limitations of perimeter security in the context of:

- stolen credentials,
- malware,
- mobile and cloud-based users.

Explain how these limitations influence modern system security design.

Question 42

Explain the “initial exchanges” in the Internet Key Exchange (IKE) in IPsec.

What are the elements that guarantee the authenticity of the involved entities (Initiator (I) and Responder (R))? How is replay prevented? What cryptographic algorithms could be used (be sufficiently specific)?

Question 43

Problems may arise with some VPN tunnels when a TCP connection is tunneled over another TCP connection when the transmission quality of the link between both VPN gateways is low.

Which solutions could you use to achieve the desired VPN security (a secure connection between two local networks) without suffering the destructive interference between both TCP connections?

Note: Don't forget to take into account the feasibility of your solutions.

Question 44

What are the advantages and drawbacks in using a TLS-based solution for secure remote login (often known as a VPN-connection) compared to using an IPsec-based solution?

Note: consider interoperability, ease-of-use (installation and maintenance), security, interaction with NAT and firewalls.

Question 45

TLS is often used as a building block for VPN solutions.

Compare TLS-based VPNs with IPsec-based VPNs.

Discuss differences in:

- security layer (network vs transport),
- compatibility with NAT and firewalls,
- operational complexity.

Explain why tunnelling TCP over TCP can be problematic.

Question 46

Explain why using the same key for CBC-encryption and for the computation of the CBC-MAC (on the same plaintext) is not secure.

Question 47

Explain the role of the “seed” in RSA-OAEP. What are the potential vulnerabilities of “raw” RSA that are eliminated (or at least very strongly mitigated) by the use of this seed (+ explain how)? How can it be recovered from an encoded message? What is a reasonable minimal length for this seed (+ explain why)?

Question 48

Quantum algorithms affect symmetric and asymmetric cryptography in fundamentally different ways.

Explain the impact of Grover’s algorithm and Shor’s algorithm on:

- symmetric encryption,
- hash functions,
- digital signatures,
- key exchange mechanisms.

For each class, discuss:

- how security strength is affected,
- whether increasing key sizes is sufficient,
- which types of algorithms must be replaced entirely.

Question 49

Post-quantum cryptography (PQC) should be resistant to quantum computer attacks like Shor's algorithm, which would make non-PQ asymmetric encryption (e.g. RSA or ECC) obsolete.

However, PQC has not been as thoroughly tested as non-PQ cryptography and might be vulnerable to non-quantum attacks. This is why so-called "hybrid encryption" has been proposed, which combines a PQC algorithm with a more proven non-PQ algorithm. The goal is to guarantee at least protection against non-quantum attacks and, hopefully (if the PQC algorithm holds), also quantum-resistant security.

Consider the case of the encapsulation of a secret key (to be used for the symmetric encryption of a file).

Suggest a hybrid encryption solution that is secure against both non-quantum attacks and post-quantum attacks against data confidentiality.

What are the advantages, risks, and drawbacks of this hybrid encryption approach?

Question 50

There is a modified version of TLS (DTLS aka Datagram TLS) allowing to offer some kind of TLS over UDP.

What might be the advantages and drawbacks in using DTLS instead of TLS in a Layer 3 VPN tunnel connecting two different local networks over the Internet.

Reminder: for those who might have forgotten what UDP is, this is a very basic transport layer protocol, running on top of IP; it is connectionless, unreliable, but fast. Packets may arrive out of order or not at all.

Question 51

Does authenticated Diffie-Hellman (DH) guarantee forward secrecy? What happens if one or both of the fixed DH keys is compromised? What is the impact on future (i.e. after the keys have been compromised) communications? What is the impact on past (i.e. before the keys have been compromised) communications?

Question 52

Rainbow tables provide a time-memory tradeoff (reasonably fast without too much storage) allowing to recover (crack) passwords from a file containing encoded passwords.

The "crack.sh" initiative offers a rainbow table approach for the DES encryption of the plaintext "1122334455667788".

Explain how such a rainbow table could help in cracking DES encryption. What might be the practical limitations? Estimate the effort required to set up this rainbow table. Estimate the storage requirements for this rainbow table. Estimate the time required to crack the encryption of "1122334455667788" with an unknown encryption key.

Question 53

In the original RSA encryption scheme the public exponent e and the private exponent d are chosen such that e is coprime to $\phi(n)$ and that $e \cdot d = 1 \pmod{\phi(n)}$, where $n = p \cdot q$.

This encryption scheme has meanwhile been somewhat modified and e and d are now chosen such that $e \cdot d = 1 \pmod{\lambda(n)}$ (without restriction on e), where $\lambda(n)$ must remain secret and

$$\lambda(n) = \text{lcm}(p-1, q-1) = \phi(n) / \text{gcd}(p-1, q-1) \quad (\text{Q53.11})$$

Explain (with sufficient mathematical detail) how the generation and the verification of a digital signature still works with this modified version of RSA. What are the advantages of this modification? How does this modification affect the computation of a digital signature using the Chinese remainder theorem? Why is it recommended that $\text{gcd}(p-1, q-1)$ should be a small value?

Question 54

When browsing the website of Bank A you can observe that the website is secured using TLS 1.2, using elliptic curve ephemeral Diffie-Hellman for the key exchange, RSA-2048 authentication for the handshake (the certificate is signed with SHA-2-256), and AES-128-GCM for the encryption of further traffic.

The website of Bank B uses slightly different security parameters: it uses TLS 1.3 with RSA-2048 authentication for the handshake (the certificate is signed with SHA-2-256), and AES-256-GCM for the encryption of further traffic.

Compare the security of the websites for Banks A and B. How significant are the differences? Which bank website offers a better level of security?